

Threat Modeling & Risk Analysis for the BSF-Nutrifeed rural deployment

Introduction

As the BSF-Nutrifeed ecosystem transitions from a conceptual model to real-world deployment in rural, resource-constrained environments, it faces unique cybersecurity challenges. In such settings, security is not just a technical necessity but a key driver of trust. For farmers and local stakeholders to confidently adopt insect-based feed solutions, their data, transactions, and operational systems must be protected against potential threats.

This task focuses on conducting a Threat Modeling and Risk Analysis to identify and contextualize vulnerabilities discovered during penetration testing. The goal is to move beyond simply identifying technical flaws to understanding their real-world impact on users, devices, and field operations. Special attention is given to the diverse technologies involved, including mobile access points, IoT devices, and cloud infrastructure, as well as the human factors present in low-literacy environments.

Using the STRIDE framework alongside a structured risk matrix approach, this analysis prioritizes threats based on their likelihood and potential impact. Insights from tools such as Nmap, Metasploit, and Burp Suite were incorporated to ensure a practical, real-world perspective. The outcome provides a clear roadmap for strengthening system security and supporting a resilient, trustworthy deployment of the BSF-Nutrifeed platform.

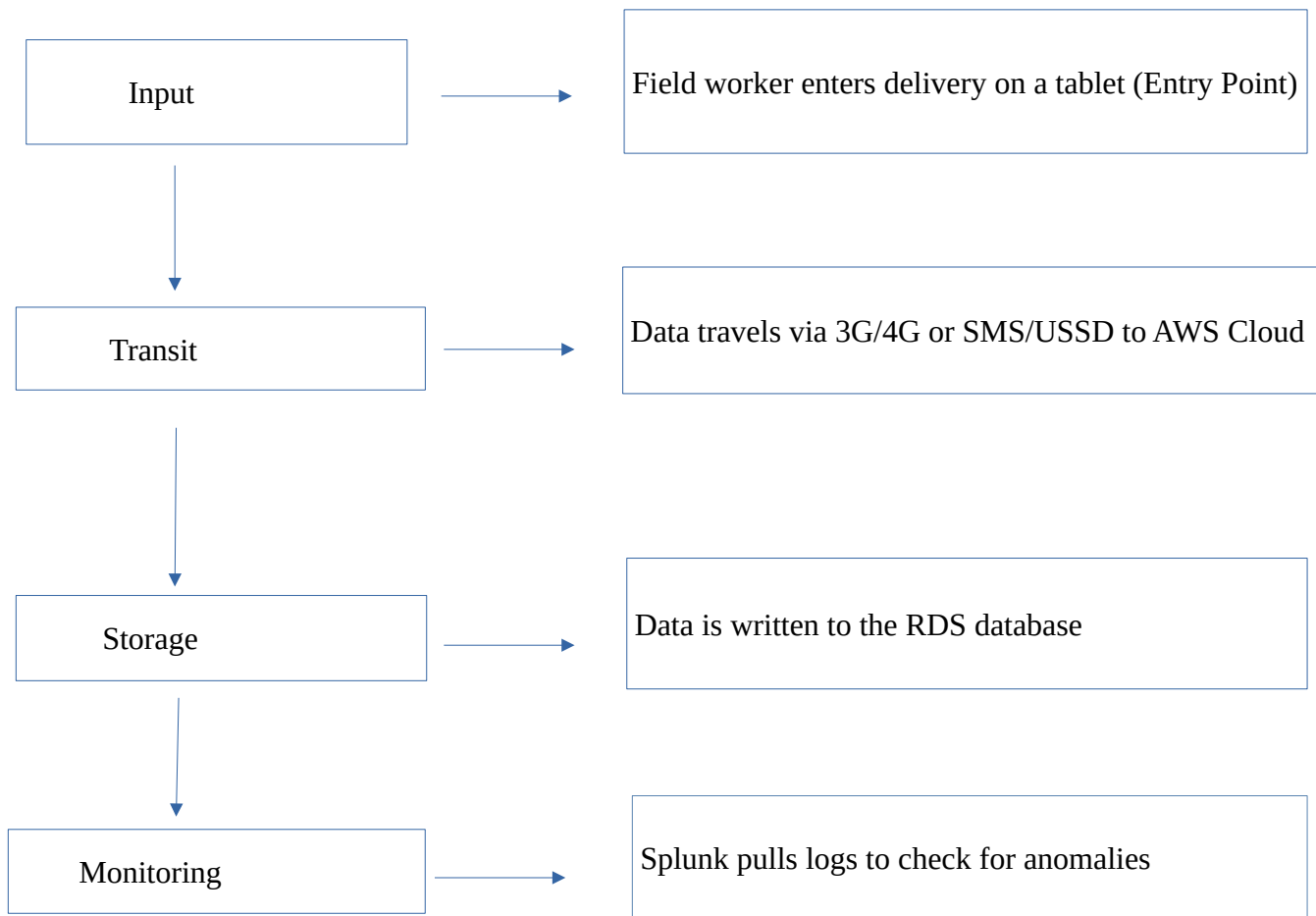
1. Defining The Scope (What we are protecting)

Assets Identification:

S/n	Assets (what we are protecting)	Descriptions
1	Data Assets	Farmer's Personal Information, Feed formulas, Transaction ledgers
2	Software Assets	Splunk Monitoring, USSD Gateway, PrestaShop/AWS Database
3	Physical Assets	Field Tablets/Smartphones, Solar Inverters/Power Supply

2. Designing a Data Flow Diagram (DFD)

Discovering Data Vulnerability Point (Tracing a bag of feed from the warehouse to the rural farmer)



3. Applying STRIDE to the Threat Modeling

Component	Threat Category (STRIDE)	Specific Rural Scenario
Field Tablet	Tampering	An unauthorized person gains access to an unlocked tablet and changes delivery amounts
Network (USSD)	Information Disclosure	Unencrypted SMS data containing farmer payment info is intercepted by a rogue base station
AWS Database	Elevation of Privilege	An attacker uses SQL Injection to gain Admin rights
Solar Inverter	Denial of Service	Physical sabotage or remote shut-off of the power supply stops the digital logging system

4. Identifying Attack Vectors and Entry Points – How the Attacker reaches BSF System

Entry Point	Vector	Impact
-------------	--------	--------

The Mobile/USSD	SIM Swapping or Phishing	Attackers can intercept OTPs, hijack farmer accounts, and divert payments meant for feed production
The Field Device	Physical theft or "Side-channel" attacks on unencrypted devices	Exposure of offline data collected during field research if the device is not hardened
The Central Cloud/Database	Exploiting vulnerabilities like vsFTPd backdoors or SQL Injection	Total compromise of the ecosystem's intellectual property and stakeholder database

5. Risk Analysis

Threat	Probability	Potential Harm (Impact)	Priority
SIM Swap Fraud targeting farmers	High	High (Financial Loss/Loss of Trust)	P1 (Critical)
SQL Injection on the Web Portal	Medium	Critical (Data Wipe/System Takeover)	P1 (Critical)
Physical Theft of a field worker's tablet	Medium	Medium (Local Data Breach)	P2 (High)
Slowloris DoS on the Splunk Monitor	Low	Low (Temporary loss of visibility)	P3 (Medium)

6. Explanation – STRIDE

- i) **Spoofing:** An attacker pretending to be a BSF-Nutrifed official to trick a farmer into giving up their credentials or feed.
- ii) **Tampering:** Maliciously changing the "quantity" of feed delivered in the digital ledger.
- iii) **Repudiation:** A user claiming they never received a payment or feed delivery because the system lacks strong logs.
- iv) **Information Disclosure:** Sensitive farmer data (location, income, phone numbers) leaking through insecure protocols like HTTP or old FTP versions.
- v) **Denial of Service:** Crashing the system (e.g., via Slowloris) so farmers cannot log their daily production, causing a backlog and loss of trust.
- vi) **Elevation of Privilege:** A low-level field worker gaining "Admin" rights to the BSF database (e.g., via SQL Injection)

7. Threat Modeling & Risk Analysis

A threat model was developed for the rural deployment of the BSF-Nutrifeed ecosystem, considering its Data Assets, Software Assets and Physical Assets. The analysis focused on identifying potential threats, attack vectors, and their impact on system security and user data.

Using the STRIDE framework, key threats such as spoofing, tampering, information disclosure, denial of service, and privilege escalation were identified. The system's primary entry points include the Mobile/USSD, Field devices, and database connections, which is often insecure. Several attack vectors were identified, including SIM swapping and phishing, physical theft, SQL injection and VSFTpd.

Risk prioritization was conducted based on probability and impact. Critical risks include SIM Swap Fraud targeting farmers, SQL Injection on the Web Portal, Physical Theft of a field worker's tablet and Slowloris DoS on the Splunk Monitor which could lead to unauthorized access and system manipulation. Critical risks include SIM Swap Fraud and SQL Injection while High and Medium risks include Physical Theft and Slowloris DoS respectively .

To mitigate these risks, recommended controls include:

- i) Patching the **vsFTPd** and **UnrealIRCd** vulnerabilities immediately. These are "open doors" that no amount of community trust can fix.
- ii) Implementing **Full Disk Encryption** on all tablets used for offline research. If a tablet is stolen in a rural village, the data remains unreadable.
- iii) Launching a "Trust Campaign" teaching them that BSF-Nutrifeed will *never* ask for their PIN or instruct them to "Press 1" during a phone call (preventing the SIM Swap fraud discussed earlier)